

QR East Industrial Database

Security Briefing for IT / Cybersecurity

Product: QuadReal Industrial Portfolio Map (Ontario)

Purpose: Internal web app for buildings, RTUs, tenants, utilities, Capex data, RTU media, and QR-360 tours

As of: 30 July 2026 | Live build v1.15.3

Classification: Internal operational data (confirm with business owner)

1. Production endpoints

URL	Role
https://qr-database.insp360.ca/	Primary friendly URL (recommended)
https://qr-east-industrial-database.pages.dev/	Cloudflare Pages origin (same app)
https://github.com/quadreal-r/QR-East_Industrial_Database	Source / version history only (not live host)

Developer localhost only: <http://127.0.0.1:5174/>

2. High-level architecture

Browser -> Cloudflare edge (Pages + optional hostname proxy) -> custom email OTP login wall (Pages Functions) -> React SPA

-> Supabase (Auth + Postgres + RLS + Edge Functions) -> Cloudflare R2 (pictures, documents, 360 deg tours).

Layer	Provider	Account / owner
Map app hosting (Pages)	Cloudflare	quadreal (quadreal.rpiwin@gmail.com)
Friendly DNS + proxy Worker	Cloudflare	krutki11 - zone insp360.ca
Database + Auth	Supabase Postgres	Project wyiymdtIncpwriuk
RTU pictures / documents (R2)	Cloudflare R2	quadreal
QR-360 tours (insp360 bucket)	Cloudflare R2	krutki11
OTP email delivery	Resend	Verified domain (e.g. insp360.ca)

Important: Two Cloudflare accounts are intentional. Map hosting and RTU media stay on quadreal; tour storage and insp360.ca DNS stay on krutki11. Credentials must not be mixed.

3. Authentication (front door)

Current control: custom email OTP wall

- Unauthenticated HTML navigations are intercepted by Cloudflare Pages middleware.
- User enters work email -> 6-digit one-time code (Resend) -> verified -> session cookie.
- Fallback: Supabase magic link if Resend is restricted (allowlist re-checked before cookie).

Who may sign in

- Emails ending in @quadreal.com, OR
- Emails explicitly added in Manage users (app_roles table)
- Non-allowed addresses do not reveal whether they are on the allowlist (anti-enumeration).

Session cookies

Cookie	Purpose	Properties
bme_otp	Pending OTP (hash only)	HttpOnly, Secure, SameSite=Lax, ~10 min
bme_session	Signed gate cookie after login	HttpOnly, Secure, SameSite=Lax, 24h, HMAC-SHA-256

After the wall

/api/session exchanges a valid gate cookie for a Supabase Auth session (access + refresh tokens) used by the SPA for database calls.

Roles

Role	Capabilities
Viewer	Sign in; browse; limited Cost Center edits (RTU \$ allocations / notes)
Admin	Full edit: markers, polygons, settings, media, users, tour publish, etc.

UI edit buttons follow role, but Postgres RLS and Edge Functions are the authoritative enforcement.

Logout clears gate cookies and Supabase browser tokens, then returns to the OTP wall.

Offline kill-switch (panic)

- Entering pulltheplug@quadreal.com on the login wall immediately flips Offline (shared panic passphrase for anyone who can reach the wall).
- Offline cuts app access (HTML gate + non-admin session mint). It does not wipe Postgres, R2, or app_roles accounts.
- Reactivation: an existing Admin completes OTP on the Off Line wall; successful Admin login clears the flag for everyone.
- Flag: app_settings key access_offline (server-side service role only).

Legacy: older Cloudflare Access / Zero Trust login may still have transitional code paths. Current design expects Access disabled on the Pages host so the OTP wall is visible.

4. Database security (Supabase)

- Engine: PostgreSQL with Row Level Security (RLS) on application tables.
- Data: buildings/RTUs/tenants/utilities, polygons, Capex/pricing/schedule, settings, media metadata, roles, activity events.
- Writes restricted to admins (is_app_editor / app_roles), with viewer exception for RTU notes/allocations.
- SUPABASE_SERVICE_ROLE_KEY is server-only (Pages Functions, Edge Functions, scripts) - never VITE_ / browser.
- VITE_SUPABASE_ANON_KEY is public by design; protection depends on RLS + Auth, not key secrecy.

Edge Functions

Function	Auth	Notes
admin-users	JWT + admin	User management
upload-insp360-cloud	JWT + admin	Short-lived R2 presigned PUT (~30 min)
list-insp360-cloud	JWT (signed-in)	Lists tour objects for sanitized prefix
delete-rtu-picture	JWT + admin	Deletes R2 object + metadata

CORS on these functions is currently open (*); protection relies on bearer JWT + role checks.

5. File / object storage (R2)

Content	Account	Access model
RTU pictures	quadreal	Public CDN bytes; metadata in Supabase
RTU documents	quadreal	Public CDN bytes; metadata in Supabase
QR-360 tours	krutki11 insp360	Public CDN for published objects; uploads via short-lived signed URLs (admin)

Implication: published media/tour URLs are world-readable if the URL is known. Upload/delete remain admin-gated. Confirm this matches data-classification policy.

6. Application API surface (Pages Functions)

Method / path	Purpose
POST /api/auth/request-code	Start OTP
POST /api/auth/verify	Verify OTP -> set bme_session
POST /api/auth/complete	Magic-link completion
GET POST /api/auth/logout	Clear gate cookies
GET /api/session	Mint Supabase session for SPA

Friendly hostname qr-database.insp360.ca is a small Worker on krutki11 that reverse-proxies to the quadreal Pages origin (same app).

7. Secrets classification

Browser-exposed (treat as public)

- VITE_SUPABASE_URL, VITE_SUPABASE_ANON_KEY
- VITE_GOOGLE_MAPS_API_KEY (HTTP referrer-restricted in Google Cloud), VITE_GOOGLE_MAPS_MAP_ID
- VITE_RTU_PICTURES_BASE_URL, VITE_RTU_DOCUMENTS_BASE_URL, VITE_INSP360_BASE_URL

Server-only (never commit / never VITE_)

- SUPABASE_SERVICE_ROLE_KEY, SUPABASE_URL
- SESSION_SECRET (HMAC for gate cookies)
- RESEND_API_KEY, RESEND_FROM
- R2_* (quadreal RTU media)
- INSP360_R2_* (krutki11 tours - separate keys)

8. Data sensitivity

Typical content: Ontario industrial addresses and portfolio structure; tenant/utility/RTU operational data; Capex/replacement-year/budget fields; operator/manager names and app user emails/roles; equipment photos/documents; 360 deg inspection tours. Treat as internal QuadReal operational data pending formal classification.

9. Controls summary

Control	Status
Front-door authentication	Email OTP (+ allowlist) before application HTML
Offline kill-switch	Panic email flips Offline; Admin OTP restores; no data wipe
Session cookie hardening	HttpOnly + Secure + SameSite=Lax + HMAC
Role-based editing	Admin vs Viewer; RLS + Edge Function checks
Secrets separation	Service role / R2 / Resend not in browser bundle
Source hosting	Live site on Cloudflare Pages (not GitHub Pages)
Account separation	Map/RTU media (quadreal) vs tours/DNS (krutki11)
Transport	HTTPS on all production hosts
Audit	Activity events for auth/actions (admin-readable)

10. Items cybersecurity may want to probe

- Public CDN media/tours - readable by URL; confirm classification policy.
- Portfolio SELECT openness via Supabase client model - OTP wall is the intended browser gate.
- Edge Function CORS * - acceptable only if JWT + role checks are trusted.
- Google Maps API key referrer allowlist should include qr-database.insp360.ca and pages.dev.
- Cross-account proxy (insp360.ca Worker -> Pages) as an extra trust boundary.
- Confirm Cloudflare Access remains disabled if OTP wall is the approved model.
- Older docs mentioning email/password are outdated; OTP + admin/viewer is current.

11. Contacts / ownership

Area	Owner
Business owner	(QuadReal - fill in)
Application maintainer	Robert Piwin / project team
Cloudflare quadreal	quadreal.rpiwin@gmail.com
Cloudflare krutki11 (tours / insp360.ca)	krutki11@gmail.com
Supabase project	wyiydmtdlncperqpwriuk

12. Internal technical references

- docs/CLOUDFLARE_ACCESS.md - login wall
- docs/CLOUDFLARE_ACCOUNTS.md - account split
- docs/DATA_ARCHITECTURE.md - data layers
- docs/INSP360_R2.md - tour storage
- supabase/README.md - database / functions
- .env.example - environment variable classification
- docs/SECURITY_BRIEF.md - markdown source of this PDF

Document generated for QuadReal IT / Cybersecurity review. Contains architecture and control descriptions only - no secret values.